

SECURITY ASSESSMENT REPORT

Vulnerability Assessment Report

Authentication Security Testing — Username Enumeration via Different Responses

PROJECT TITLE	Professional Vulnerability Assessment Report
TARGET PLATFORM	PortSwigger Web Security Academy
CATEGORY	Authentication
VULNERABILITY	Username Enumeration via Different Responses
LAB DIFFICULTY	Apprentice

STUDENT NAME	Shantanu Gayke
Organization	Cryptonic Area
Intern ID	CA0149
DATE	5 August, 2026

Prepared for Internship Submission

Confidential — for academic and internship evaluation purposes only

Educational Security Assessment

Conducted in an Authorized Training Environment

EXECUTIVE SUMMARY · AT A GLANCE

Risk Rating: **MEDIUM** · OWASP A07:2021 · CWE-203

The login form unintentionally confirms whether a username is registered. Fixing this requires no architectural change — only consistent, generic responses across all authentication endpoints.

Table of Contents

Vulnerability Assessment Report — Authentication Security Testing

1. Executive Summary 3

2. Engagement Details..... 4

3. Scope..... 4

4. Methodology..... 5

5. Vulnerability Overview..... 6

6. Technical Analysis..... 7

7. Risk Assessment 8

8. Proof of Concept 9-13

9. Impact13

10. Remediation.....14

11. Conclusion.....15

12. References15

1. Executive Summary

This report presents the findings of a security assessment carried out on a controlled lab environment hosted by PortSwigger Web Security Academy. The assessment focused on the authentication workflow of the target application, specifically how the login form handles valid and invalid username submissions.

Testing showed that the application returns two different error messages during login attempts: one when a submitted username does not exist, and another when the username exists but the password is incorrect. This difference allows anyone interacting with the login form to determine which usernames are registered, without needing any prior knowledge of valid accounts.

On its own, this issue does not expose passwords or grant unauthorized access. It does, however, remove a layer of uncertainty that authentication systems normally rely on to slow attackers down. Once valid usernames are known, follow-on attacks such as password brute-forcing, credential stuffing, and targeted phishing become considerably easier to carry out. This finding is rated Medium risk and is recommended for remediation as part of routine authentication hardening.

KEY TAKEAWAY

The login form unintentionally confirms whether a username is registered. Fixing this requires no architectural change — only consistent, generic responses across all authentication endpoints.

2. Engagement Details

Assessment Type	Web Application Security Testing — Authentication Module
Platform	PortSwigger Web Security Academy (Lab Environment)
Target	“Username Enumeration via Different Responses” — Login Functionality
Testing Environment	Isolated, intentionally vulnerable lab instance provided by PortSwigger; no shared or production infrastructure involved
Lab Difficulty	Apprentice
Tester	Shantanu Gayke

Authorization Statement

This assessment was carried out entirely within a sandboxed lab instance made available by PortSwigger Web Security Academy for training purposes. Access to and testing of this lab is explicitly permitted under PortSwigger's terms for registered Academy users. At no point during this engagement was any system outside the lab environment accessed, scanned, or tested.

3. Scope

The scope of this engagement was limited to a single, purpose-built lab application provided by PortSwigger Web Security Academy. No real, production, or third-party systems were involved at any stage of testing.

In Scope

- Login page and authentication logic of the PortSwigger lab application
- HTTP request and response behaviour during login attempts
- Error message handling for valid and invalid usernames

Out of Scope

- Any system, domain, or application outside the designated lab instance
- Other PortSwigger Academy labs not part of this assessment
- Underlying PortSwigger infrastructure, hosting, or platform source code

⚠ TESTING BOUNDARY

All testing activity described in this report was confined to the intentionally vulnerable lab application. No real, production, or third-party systems were targeted at any stage of this engagement.

4. Methodology

Testing followed a manual-first approach, using Burp Suite Community Edition to observe and control HTTP traffic between the browser and the lab application. The steps below outline how the assessment was carried out.

- **Reconnaissance:** Reviewed the login page and normal authentication flow to understand expected application behaviour.
- **Traffic Interception:** Routed browser traffic through Burp Suite Community Edition and captured a baseline login request.
- **Manual Testing:** Submitted a random, clearly invalid username and password to record the application's default error response.
- **Controlled Username Testing:** Sent the captured login request to Burp Intruder and ran it against the candidate username wordlist supplied within the lab, comparing response length and content for each attempt.
- **Response Analysis:** Identified the single request that returned a different message from the rest, indicating a valid, registered username.
- **Controlled Password Testing:** Repeated the Intruder process against the password field, using the confirmed username together with the candidate password wordlist provided by the lab.
- **Verification:** Logged in using the identified credentials to confirm the vulnerability and complete the lab objective.

Testing Workflow



Figure A — End-to-end testing workflow followed during this engagement

i TOOLING NOTE

This testing used only the small, lab-provided candidate lists intended for training purposes. No external wordlists, automated scanners, or large-scale brute-force tooling were used at any point.

5. Vulnerability Overview

What Is Username Enumeration?

Username enumeration is a weakness where an application unintentionally reveals whether a given username or email address is registered, typically through differences in login, registration, or password-reset responses. The application does not need to leak a password — simply confirming that an account exists is enough to give an attacker a useful starting point.

How Does It Happen?

It usually happens when developers write separate error messages for different failure conditions — for example, “user not found” versus “wrong password” — without realising that the wording, or even subtler signals like response length, timing, or status code, gives away information the application should not disclose.

Why Is It Dangerous?

Knowing that a username exists is not, by itself, a breach. The danger comes from what it enables next. Attackers rarely brute-force passwords against unknown usernames, since it is slow and inefficient. Enumeration removes that uncertainty, letting attackers focus password-guessing and credential-stuffing efforts only on accounts confirmed to exist.

Real-World Impact

This class of vulnerability has been observed on login and password-reset endpoints across many types of platforms, including e-commerce, SaaS, and financial services. Attackers have used it to build lists of valid accounts ahead of large-scale credential stuffing campaigns, typically as an early step before a more damaging attack.

6. Technical Analysis

The lab's login form accepts a username and a password field. During testing, two distinct application behaviours were observed depending on the submitted username:

Login Attempt	Application Response
Username does not exist	"Invalid username."
Username exists, password incorrect	"Incorrect password."

Because the wording changes based solely on whether the username exists, an attacker does not need to guess a correct password to confirm an account. Submitting a list of candidate usernames and observing which single response differs from the rest is sufficient to identify a valid account — the password field is irrelevant at this stage.

This defeats the purpose of a login form designed so that a failed attempt reveals nothing about why it failed. Standard authentication design assumes an attacker cannot distinguish between the two failure conditions. Once that assumption breaks, the login form effectively becomes an oracle: submit a username, and the application confirms whether it exists.

In this case, the difference was visible directly in the message text, making it detectable through simple manual testing and trivial to automate using Burp Intruder's built-in response comparison features, such as response length, word count, and status code.

Authentication Attack Flow

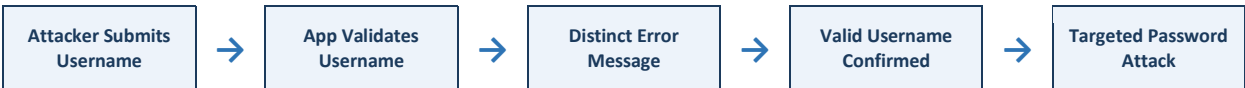


Figure B — How a response-based difference in login errors leads to username enumeration

7. Risk Assessment

Risk Level	MEDIUM
Likelihood	High — requires no special access and is easily automated
Business Impact	Medium — does not directly compromise data but materially assists further attacks
Affected Component	Login / Authentication Endpoint
OWASP Category	OWASP A07:2021 — Identification and Authentication Failures
CWE Reference	CWE-203 — Observable Discrepancy
CVSS Base Score	5.3 (Medium) — Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Risk Matrix

Likelihood ↓ / Impact →	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	Medium
High	Medium	Medium ◀ This Finding	High

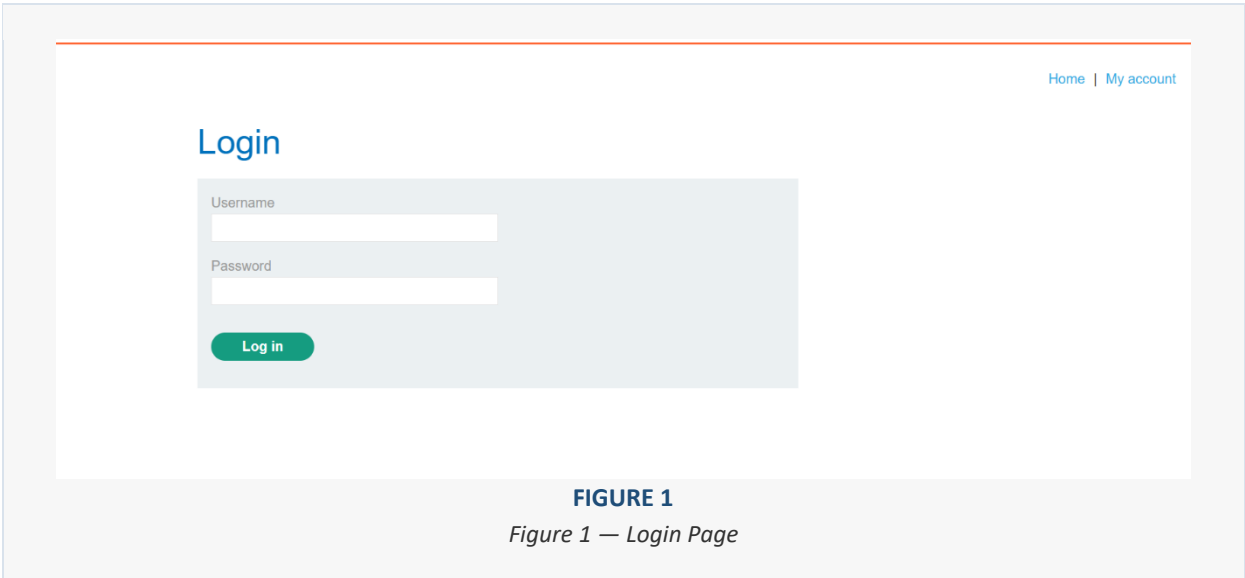
This finding combines high likelihood with medium business impact, placing it in the Medium risk band — consistent with the CVSS 5.3 score above.

8. Proof of Concept

The steps below reproduce the vulnerability as observed during testing.

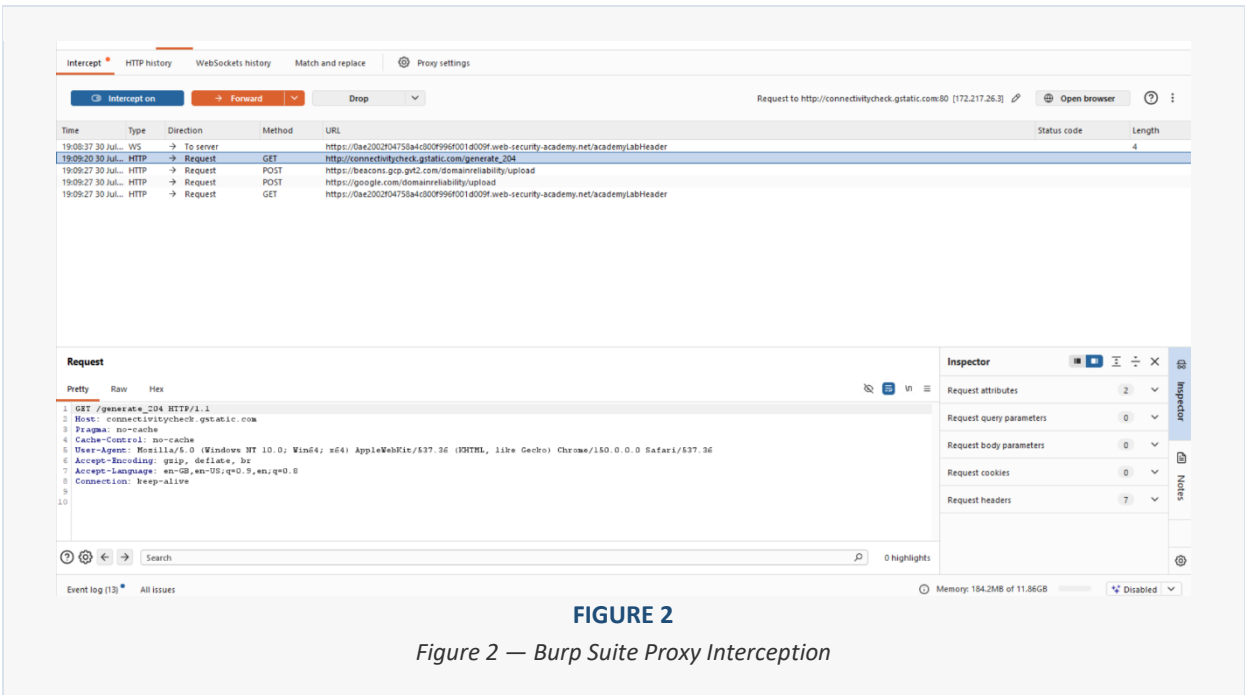
Step 1: Access the Login Page

Navigated to the lab's login page and reviewed the standard authentication form.



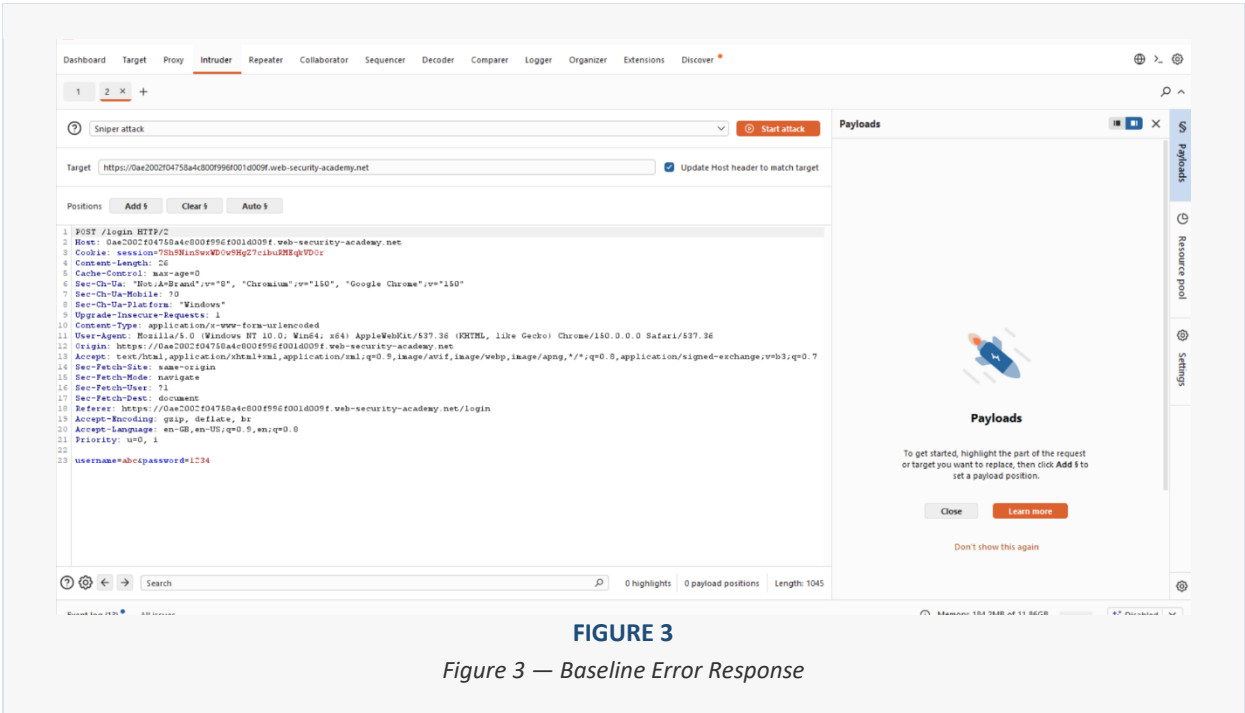
Step 2: Intercept Traffic with Burp Suite

Configured the browser proxy to route traffic through Burp Suite Community Edition and captured a login request.



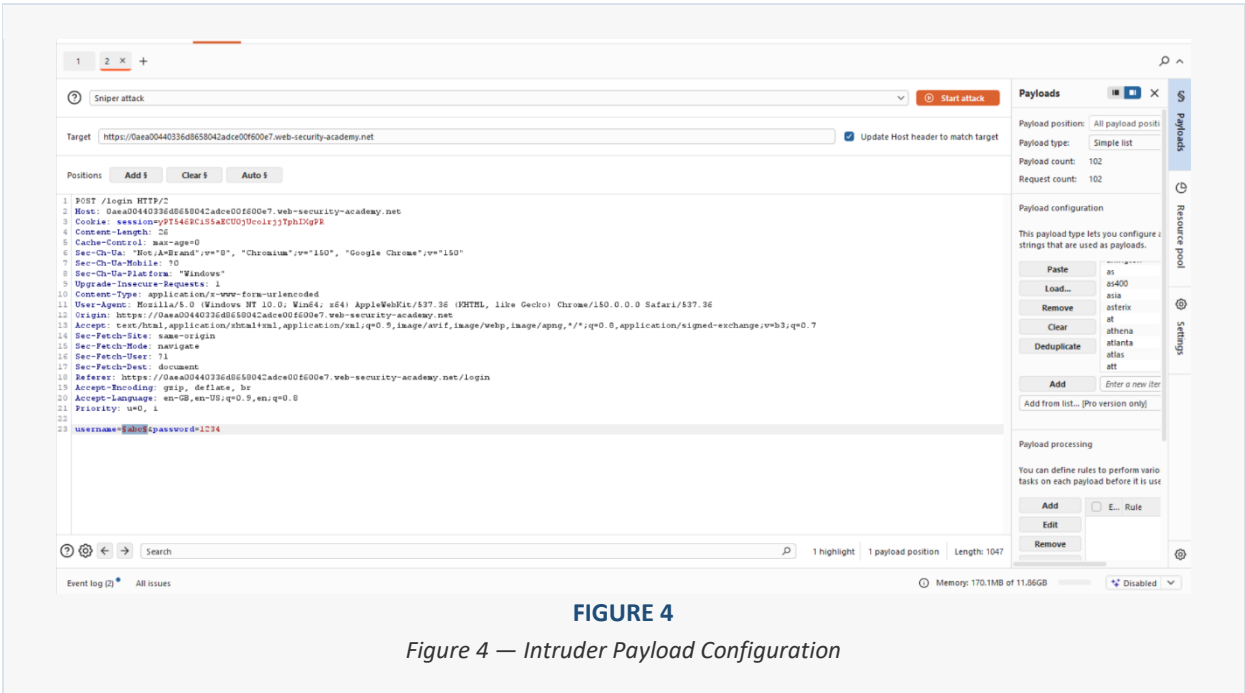
Step 3: Establish a Baseline Response

Submitted a random, invalid username with an arbitrary password and recorded the response: “Invalid username.”



Step 4: Configure Burp Intruder

Sent the captured request to Burp Intruder and marked the username field as the payload position, loading the lab-provided candidate username list.



Step 5: Run the Username Attack

Executed the Intruder attack and sorted results by response length. One request returned “Incorrect password” instead of “Invalid username,” revealing a valid, registered username.

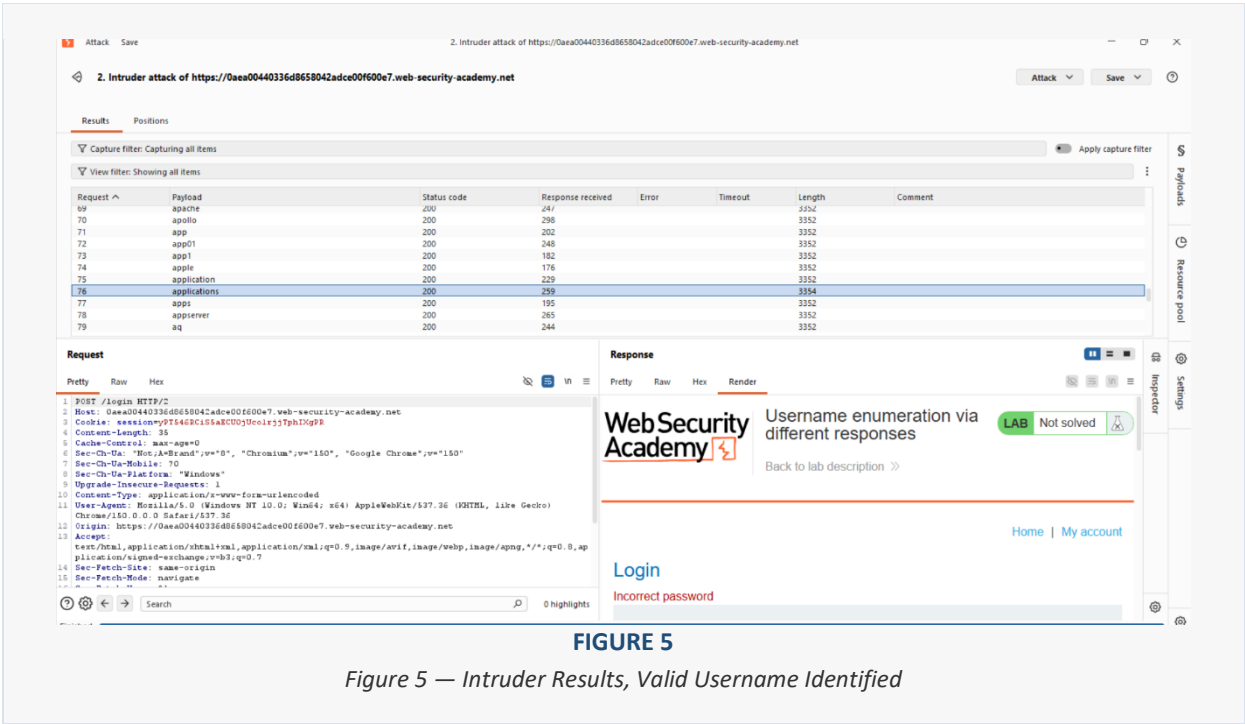


FIGURE 5
Figure 5 — Intruder Results, Valid Username Identified

Step 6: Configure the Password Attack

Using the confirmed username, sent a fresh request to Intruder and marked the password field as the payload position, loading the lab-provided candidate password list.

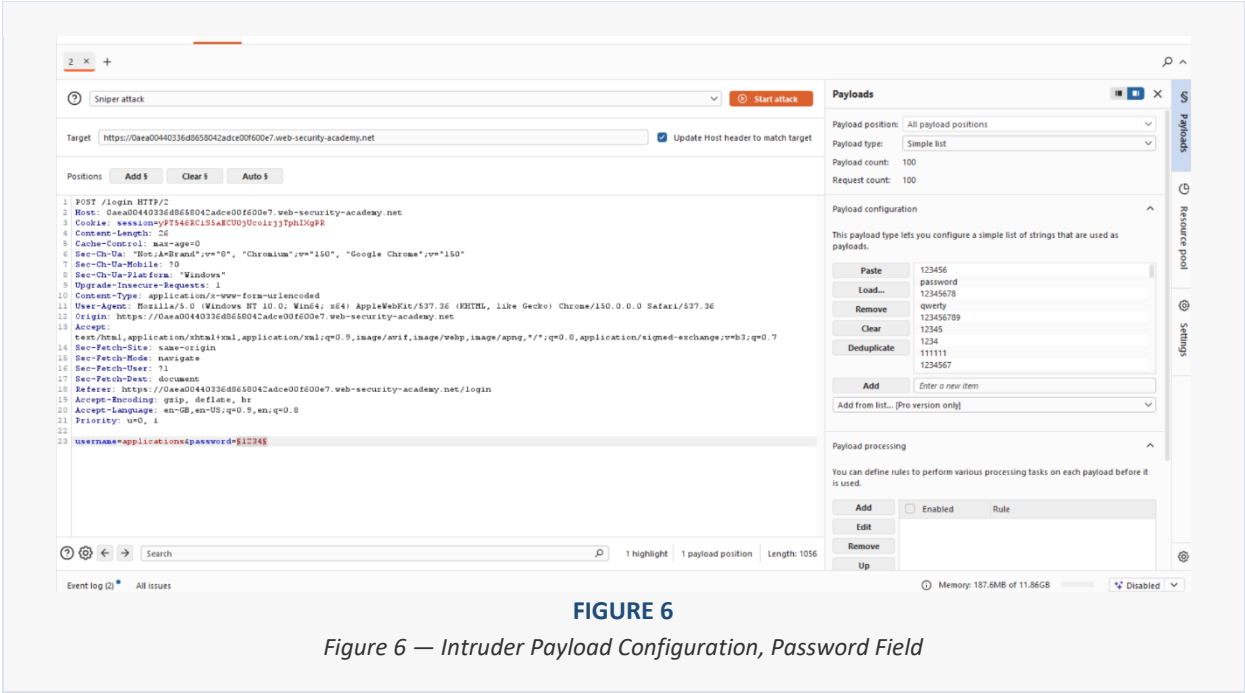


FIGURE 6
Figure 6 — Intruder Payload Configuration, Password Field

Step 7: Identify the Correct Password

Ran the attack and identified the request returning a different response (redirect / status code), indicating the correct password.

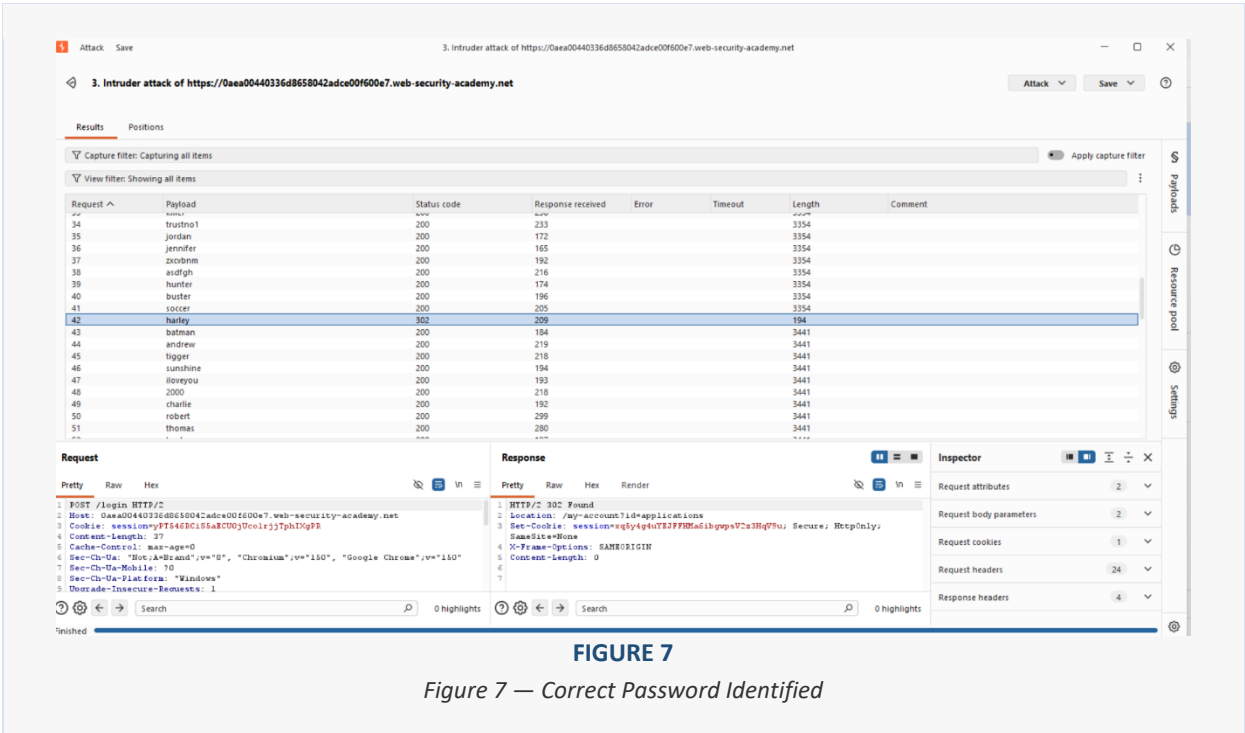


FIGURE 7
Figure 7 — Correct Password Identified

Step 8: Verify Access

Logged in using the discovered username and password to confirm the vulnerability and complete the lab objective.

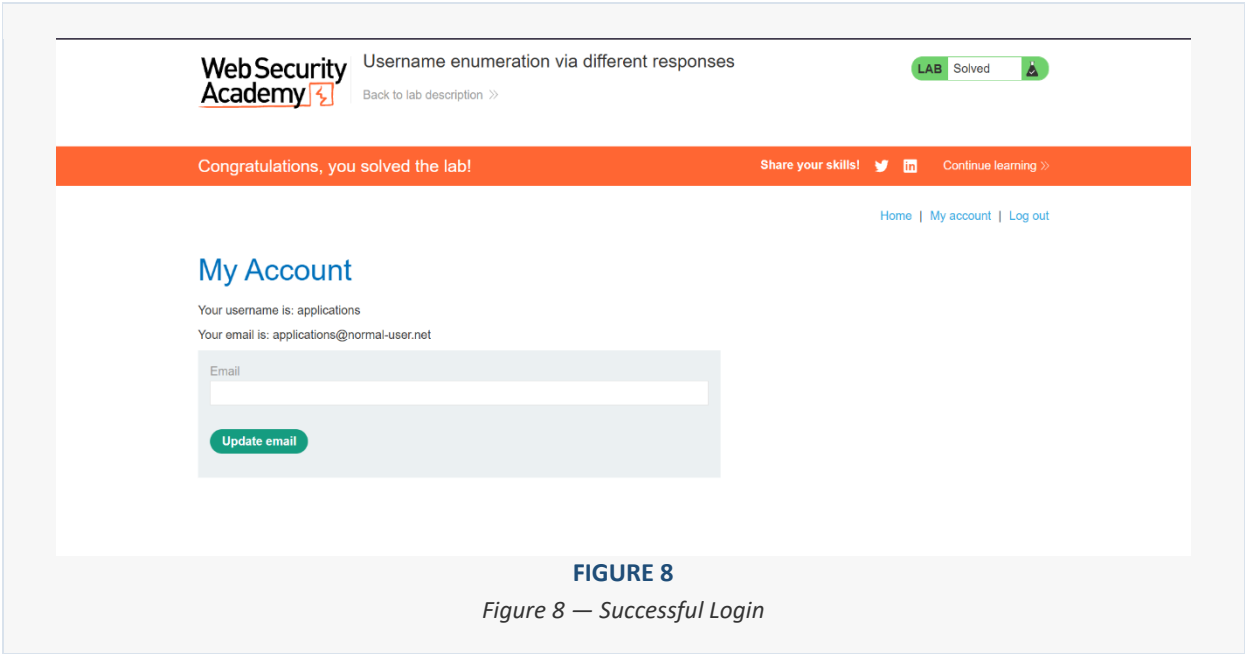


FIGURE 8
Figure 8 — Successful Login

Results

- Expected Result: The application should return an identical, generic error message regardless of whether the submitted username exists.

- **Actual Result:** The application returned “Invalid username” for non-existent accounts and “Incorrect password” for existing accounts, disclosing valid usernames.
- **Observation:** The differing responses allowed complete enumeration of a valid account using an automated Intruder attack within minutes, which in turn enabled a successful password attack against the test account.

9. Impact

If left unaddressed, this vulnerability can contribute to the following outcomes:

Credential Attacks

Confirmed usernames let attackers focus brute-force and credential-stuffing attempts only on real accounts, improving their chances of success.

Targeted Attacks

Known valid usernames or email addresses can be used to craft convincing, personalised phishing messages aimed at specific users.

Reduced Password Security

Removing username uncertainty effectively strips away one layer of the authentication process, leaving account security dependent entirely on password strength.

Information Disclosure

The application unintentionally confirms which individuals or organisations use the platform, which can itself be sensitive business information.

User Privacy Risks

On platforms where account membership implies something personal — health, financial, or support services, for example — confirming that a specific email or username exists can expose private details about a person.

10. Remediation

The following measures are recommended to close this gap and strengthen the overall authentication process:

Recommendation	Priority
Use a single, generic error message (e.g. "Invalid username or password") for all failed login attempts, regardless of the reason.	High
Ensure response time, length, and status code stay consistent between valid and invalid username attempts, to prevent indirect enumeration.	High
Apply the same generic-response principle to registration and password-reset flows, which are common alternate sources of the same weakness.	High
Apply rate limiting on login attempts, both per IP address and per account, to slow down automated testing.	Medium
Introduce account lockout or progressive delays after repeated failed login attempts.	Medium
Add CAPTCHA or an equivalent challenge mechanism after a small number of failed attempts.	Medium
Log and monitor repeated failed login attempts, particularly patterns consistent with enumeration or brute-force activity.	Medium
Offer multi-factor authentication (MFA) so a correctly guessed password alone is not sufficient to access an account.	Low
Follow established secure authentication practices, such as those in the OWASP Authentication Cheat Sheet, when designing or reviewing login systems.	Low

Priority reflects recommended implementation order, consistent with the guidance below.

✓ PRIORITY FIX

Standardising the login error message is a low-effort, high-value change. It should be treated as the first fix, ahead of the more involved controls such as MFA and rate limiting.

11. Conclusion

This assessment confirmed that the target lab application discloses valid usernames through inconsistent login error messages — a textbook example of a username enumeration vulnerability. While the issue does not directly grant access to an account, it meaningfully lowers the effort required for an attacker to run a successful password attack.

The fix is straightforward and low-cost: standardise error messages and response behaviour across all authentication-related endpoints. Implementing the remediation steps outlined in this report would close this gap without affecting the usability of the login process for legitimate users.

This exercise reinforced that authentication error handling is a security-relevant design decision, not just a usability detail — a principle that applies well beyond this lab environment.

12. References

- OWASP Authentication Cheat Sheet — cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP Application Security Verification Standard (ASVS) — owasp.org/www-project-application-security-verification-standard
- PortSwigger Web Security Academy — portswigger.net/web-security